

Tugas 12 - Self-Learning Security Testing

1. OWASP Top 10

OWASP Top 10 merupakan standar awareness yang berisi daftar risiko keamanan paling penting pada aplikasi web. OWASP Top 10 dapat digunakan sebagai acuan bagi developer maupun tester untuk memahami dan mengidentifikasi risiko keamanan yang umum ditemukan pada aplikasi. Versi terbaru yang digunakan saat ini adalah **OWASP Top 10:2025**.

1. Broken Access Control

Broken Access Control terjadi ketika aplikasi tidak menerapkan pembatasan akses dengan benar sehingga pengguna dapat mengakses data atau fitur yang seharusnya tidak diperbolehkan.

Contohnya, user biasa dapat membuka halaman administrator atau mengakses data milik user lain hanya dengan mengubah parameter pada URL.

Dalam security testing, tester dapat mencoba mengakses fitur atau data menggunakan role yang berbeda untuk memastikan setiap user hanya dapat mengakses resource sesuai hak aksesnya.

2. Security Misconfiguration

Security Misconfiguration terjadi ketika konfigurasi keamanan pada aplikasi, server, database, atau komponen lainnya tidak diterapkan dengan benar.

Contohnya adalah penggunaan konfigurasi default, fitur debugging yang masih aktif, atau informasi error yang terlalu detail.

Tester dapat memeriksa konfigurasi aplikasi dan melihat apakah informasi sensitif atau informasi mengenai sistem dapat diketahui melalui error message maupun response aplikasi.

3. Software Supply Chain Failures

Software Supply Chain Failures berkaitan dengan risiko keamanan yang berasal dari software, library, dependency, atau komponen pihak ketiga yang digunakan oleh aplikasi.

Contohnya, sebuah aplikasi menggunakan library yang memiliki vulnerability sehingga aplikasi tersebut juga berpotensi terkena dampaknya.

Security testing dapat dilakukan dengan memeriksa dependency dan komponen pihak ketiga yang digunakan untuk memastikan tidak terdapat vulnerability yang diketahui.

4. Cryptographic Failures

Cryptographic Failures terjadi ketika mekanisme perlindungan terhadap data menggunakan kriptografi tidak diterapkan dengan benar.

Contohnya adalah data sensitif tidak dienkripsi atau password tidak disimpan menggunakan mekanisme hashing yang sesuai.

Tester perlu memastikan data sensitif seperti password dan informasi pribadi mendapatkan perlindungan yang memadai ketika disimpan maupun dikirim.

5. Injection

Injection terjadi ketika input dari pengguna diproses oleh aplikasi sehingga input tersebut dapat memengaruhi perintah atau query yang dijalankan oleh sistem.

Salah satu contoh yang umum adalah **SQL Injection**, ketika input pengguna dapat memengaruhi query database.

Security testing dapat dilakukan dengan menguji berbagai input pada form, parameter URL, maupun API untuk memastikan input tersebut divalidasi dan ditangani dengan aman.

6. Insecure Design

Insecure Design merupakan kelemahan keamanan yang berasal dari desain atau arsitektur aplikasi.

Contohnya adalah sistem login tidak memiliki mekanisme pembatasan terhadap percobaan login yang terlalu banyak sehingga memungkinkan terjadinya brute-force attack.

Security testing tidak hanya dilakukan terhadap implementasi kode, tetapi juga perlu mempertimbangkan apakah desain sistem sudah memiliki mekanisme keamanan yang sesuai.

7. Authentication Failures

Authentication Failures terjadi ketika mekanisme autentikasi aplikasi memiliki kelemahan sehingga identitas pengguna tidak dapat diverifikasi atau dilindungi dengan baik.

Contohnya adalah penggunaan password yang lemah, session yang tidak dikelola dengan baik, atau mekanisme login yang tidak memiliki perlindungan terhadap percobaan login berulang.

Tester dapat menguji login menggunakan credential yang valid dan tidak valid, password reset, session, logout, serta mekanisme autentikasi lainnya.

8. Software or Data Integrity Failures

Kategori ini berkaitan dengan kegagalan dalam menjaga integritas software dan data yang digunakan oleh aplikasi.

Contohnya adalah aplikasi menggunakan komponen atau update dari sumber yang tidak terpercaya atau data dapat dimodifikasi tanpa adanya validasi.

Security testing dilakukan untuk memastikan software dan data yang digunakan berasal dari sumber yang dapat dipercaya dan tidak mengalami perubahan yang tidak sah.

9. Security Logging and Alerting Failures

Security Logging and Alerting Failures terjadi ketika aktivitas keamanan tidak dicatat atau sistem tidak memberikan alert yang sesuai ketika terjadi aktivitas mencurigakan.

Contohnya adalah terdapat banyak percobaan login menggunakan password yang salah tetapi aktivitas tersebut tidak tercatat atau tidak menghasilkan peringatan.

Logging dan alerting penting agar aktivitas mencurigakan dapat dideteksi dan ditindaklanjuti.

10. Mishandling of Exceptional Conditions

Mishandling of Exceptional Conditions terjadi ketika aplikasi tidak menangani kondisi error atau kondisi tidak normal dengan aman.

Contohnya adalah aplikasi menampilkan stack trace atau informasi internal database kepada pengguna ketika terjadi error.

Tester dapat memberikan input yang tidak valid atau menyebabkan kondisi error untuk memastikan aplikasi memberikan response yang aman tanpa membocorkan informasi internal.

Daftar OWASP Top 10:2025 terdiri dari sepuluh kategori di atas dan menjadi salah satu framework yang dapat digunakan untuk membantu menentukan security test case.

2. Tools of Security Testing

Security testing tools digunakan untuk membantu menemukan, menganalisis, dan memvalidasi vulnerability pada aplikasi, API, jaringan, maupun sistem. Penggunaan tools dapat membantu proses security testing menjadi lebih cepat dan sistematis.

1. OWASP ZAP

OWASP ZAP (Zed Attack Proxy) merupakan security testing tool yang digunakan untuk melakukan pengujian terhadap aplikasi web.

ZAP dapat membantu tester dalam melakukan scanning dan menganalisis komunikasi antara client dengan server.

Contoh penggunaan ZAP:

- Melakukan security scanning pada aplikasi web.
- Melihat HTTP request dan response.
- Mencari potensi vulnerability.
- Menguji input dan parameter aplikasi.

- Membantu melakukan vulnerability assessment.

ZAP cocok digunakan untuk pembelajaran karena merupakan salah satu tool open-source yang banyak digunakan dalam web security testing.

2. Burp Suite Community

Burp Suite Community Edition merupakan kumpulan tools untuk melakukan pengujian keamanan aplikasi web.

Salah satu fungsi utamanya adalah sebagai proxy sehingga tester dapat melihat dan menganalisis request yang dikirimkan browser ke server.

Burp Suite dapat digunakan untuk membantu pengujian:

- Authentication.
- Authorization.
- Session.
- Input validation.
- API.
- HTTP request dan response.

Tester dapat menggunakan fitur seperti Proxy dan Repeater untuk mengamati serta menguji kembali request dengan perubahan tertentu.

3. Nmap

Nmap (Network Mapper) merupakan tool yang digunakan untuk network discovery dan security auditing.

Nmap dapat membantu tester mengetahui:

- Host yang aktif.
- Port yang terbuka.
- Service yang berjalan.
- Informasi mengenai service pada sebuah host.

Nmap lebih banyak digunakan pada sisi **network security testing** dibandingkan pengujian fungsional aplikasi.

4. Nikto

Nikto merupakan web server scanner yang digunakan untuk membantu menemukan berbagai masalah keamanan pada web server.

Nikto dapat digunakan untuk mencari konfigurasi atau file yang berpotensi bermasalah serta mengetahui informasi mengenai software yang digunakan oleh web server.

Tool seperti Nikto dapat membantu tester melakukan pemeriksaan awal terhadap keamanan web server.

5. SAST Tools

SAST (Static Application Security Testing) digunakan untuk menganalisis source code tanpa menjalankan aplikasi.

Tujuannya adalah menemukan potensi security vulnerability pada kode sejak tahap awal pengembangan.

Contohnya adalah menemukan potensi masalah pada input validation atau pola kode yang dapat menyebabkan vulnerability.

SAST mendukung pendekatan **shift-left security**, yaitu melakukan pengujian keamanan lebih awal dalam SDLC.

6. DAST Tools

DAST (Dynamic Application Security Testing) melakukan pengujian terhadap aplikasi yang sedang berjalan.

Berbeda dengan SAST yang memeriksa source code, DAST menguji aplikasi dari sisi eksternal untuk melihat bagaimana aplikasi merespons berbagai request dan input.

Contoh pengujian DAST adalah vulnerability scanning dan penetration testing pada aplikasi yang sedang berjalan.

7. SCA Tools

SCA (Software Composition Analysis) digunakan untuk menganalisis dependency dan komponen pihak ketiga yang digunakan dalam aplikasi.

SCA dapat membantu menemukan dependency yang memiliki vulnerability atau menggunakan versi yang memiliki masalah keamanan.

Security Testing Guidelines juga mencantumkan penggunaan SCA untuk melakukan pemeriksaan terhadap software dependencies dan komponen pihak ketiga.

3. Authentication & Authorization

Authentication dan Authorization merupakan bagian penting dalam security testing karena keduanya berkaitan dengan keamanan akses pengguna terhadap sistem. Security testing perlu memastikan bahwa hanya pengguna yang valid yang dapat masuk dan pengguna tersebut hanya dapat mengakses resource sesuai haknya.

Authentication

Authentication adalah proses untuk memverifikasi identitas pengguna sebelum pengguna mendapatkan akses ke sistem.

Contoh authentication:

- Username dan password.
- OTP.
- Multi-Factor Authentication.
- Biometric.
- Authentication token.

Contoh security test pada authentication:

1. Login menggunakan username dan password yang benar.
2. Login menggunakan password yang salah.
3. Login menggunakan username yang tidak terdaftar.
4. Mencoba login berkali-kali menggunakan credential yang salah.
5. Memastikan password tidak ditampilkan secara langsung.
6. Memastikan user dapat melakukan logout dengan benar.
7. Memastikan session berakhir setelah logout atau timeout.
8. Menguji proses forgot password atau password reset.

Pengujian authentication bertujuan memastikan hanya pengguna yang berhasil diverifikasi yang dapat masuk ke sistem.

Authorization

Authorization adalah proses menentukan resource atau fitur apa saja yang boleh diakses oleh pengguna setelah berhasil melakukan authentication.

Contohnya pada aplikasi dengan beberapa role:

- Admin dapat mengelola seluruh data.
- Staff dapat mengakses fitur tertentu.
- Customer hanya dapat menggunakan fitur yang diperuntukkan bagi customer.

Contoh security test pada authorization:

1. Login sebagai customer.
2. Mencoba membuka halaman admin.

3. Mencoba mengakses endpoint yang hanya diperbolehkan untuk admin.
4. Mencoba mengakses data milik user lain.
5. Mencoba melakukan aksi yang tidak sesuai dengan role.
6. Memastikan setiap role hanya dapat menggunakan fitur yang telah ditentukan.

Perbedaan Authentication dan Authorization

Authentication	Authorization
Memverifikasi identitas pengguna	Menentukan hak akses pengguna
Dilakukan untuk mengetahui siapa pengguna	Menentukan apa yang boleh dilakukan pengguna
Contoh: Login username dan password	Contoh: Admin dapat menghapus produk
Fokus pada identity	Fokus pada permission/access

Contoh sederhananya:

Authentication: "Apakah kamu benar-benar Ahmad?"

Authorization: "Setelah Ahmad login, apakah Ahmad boleh menghapus data produk?"

Keduanya harus diuji karena aplikasi dapat memiliki authentication yang berjalan dengan baik tetapi tetap memiliki vulnerability pada authorization.

4. Types of Security Testing

Security testing memiliki beberapa metode yang digunakan untuk menemukan vulnerability dan mengevaluasi kemampuan sistem dalam menghadapi ancaman keamanan. Jenis pengujian dapat dilakukan menggunakan pendekatan manual maupun automated testing.

1. Vulnerability Scanning

Vulnerability scanning merupakan proses untuk mencari vulnerability yang sudah diketahui pada aplikasi, sistem, atau jaringan.

Biasanya proses ini dapat dilakukan menggunakan automated tools sehingga pemeriksaan dapat dilakukan secara lebih cepat.

Contohnya adalah melakukan scanning untuk menemukan:

- Software yang memiliki vulnerability.
- Konfigurasi yang tidak aman.
- Password yang lemah.

- Dependency yang memiliki vulnerability.

Hasil scanning kemudian dapat dianalisis untuk menentukan vulnerability yang perlu diperbaiki.

2. Security Scanning

Security scanning memiliki cakupan yang lebih luas karena dapat mencakup berbagai bagian environment yang mendukung aplikasi, termasuk network dan infrastructure.

Contohnya adalah melakukan pemeriksaan terhadap:

- Open ports.
- Network configuration.
- Firewall.
- Service yang berjalan.
- Konfigurasi sistem.

Security scanning membantu memastikan bukan hanya aplikasinya yang aman, tetapi environment yang mendukung aplikasi juga diperiksa.

3. Penetration Testing

Penetration testing atau **pentest** merupakan pengujian dengan melakukan simulasi serangan terhadap sistem untuk menemukan vulnerability yang dapat dimanfaatkan oleh attacker.

Tujuan pentest adalah mengetahui apakah vulnerability tertentu benar-benar dapat dimanfaatkan dan seberapa besar dampaknya terhadap sistem.

Contohnya adalah tester mencoba melakukan pengujian terhadap authentication, authorization, input validation, atau konfigurasi aplikasi.

Penetration testing harus dilakukan secara terkontrol dan mendapatkan izin dari pemilik sistem.

4. Security Auditing

Security auditing merupakan proses pemeriksaan terhadap sistem, konfigurasi, source code, maupun prosedur keamanan untuk memastikan semuanya telah sesuai dengan standar atau requirement yang ditentukan.

Contohnya:

- Memeriksa konfigurasi keamanan.
- Memeriksa access control.
- Memeriksa logging.

- Melakukan source code review.
- Memeriksa penerapan security policy.

Security Testing Guidelines juga menjelaskan source code review sebagai salah satu aktivitas security testing yang dapat dilakukan dengan mengacu pada standar seperti OWASP Code Review Guide.

5. Risk Assessment

Risk assessment digunakan untuk mengidentifikasi dan menilai risiko yang terdapat pada sistem.

Risk assessment membantu menentukan vulnerability mana yang memiliki risiko paling tinggi berdasarkan kemungkinan terjadinya dan dampaknya terhadap sistem atau data.

Contohnya, vulnerability yang memungkinkan attacker mendapatkan akses ke data seluruh pengguna memiliki risiko yang lebih tinggi dibandingkan vulnerability yang hanya menampilkan informasi error sederhana.

6. Ethical Hacking

Ethical hacking merupakan aktivitas pengujian keamanan yang dilakukan secara legal dan mendapatkan izin dari pemilik sistem.

Ethical hacker menggunakan teknik yang menyerupai attacker untuk mencari kelemahan pada sistem, tetapi tujuan akhirnya adalah membantu organisasi memperbaiki vulnerability tersebut.

Penetration testing merupakan salah satu aktivitas yang dapat dilakukan dalam pendekatan ethical hacking.

7. External Security Testing

External security testing dilakukan dengan melihat keamanan sistem dari sisi luar, seperti seorang attacker yang tidak memiliki akses internal.

Pengujian dapat dilakukan terhadap sistem yang dapat diakses dari internet, seperti website, server, dan endpoint tertentu.

Contohnya:

- Port scanning.
- Vulnerability scanning.
- Web application testing.
- Penetration testing.

Tujuannya adalah mengetahui seberapa baik sistem menghadapi ancaman yang berasal dari luar.

8. Internal Security Testing

Internal security testing dilakukan dari sisi internal environment untuk mengetahui apakah terdapat kelemahan yang dapat dimanfaatkan oleh seseorang yang sudah memiliki akses ke jaringan atau sistem internal.

Pengujian dapat mencakup pemeriksaan access control, konfigurasi jaringan, privilege user, serta resource internal.

9. Input Validation Testing

Input validation testing bertujuan memastikan input yang diberikan pengguna divalidasi dan ditangani dengan benar oleh aplikasi.

Pengujian dapat dilakukan pada:

- Web form.
- API parameter.
- File upload.
- URL parameter.
- Database input.

Tester dapat menggunakan berbagai input tidak valid atau tidak terduga untuk melihat bagaimana aplikasi meresponsnya.

Input validation penting untuk membantu mencegah serangan seperti **SQL Injection** dan **Cross-Site Scripting (XSS)**.

10. SAST

SAST atau **Static Application Security Testing** melakukan analisis terhadap source code tanpa menjalankan aplikasi.

SAST dapat membantu menemukan security vulnerability lebih awal dalam proses pengembangan. Karena dilakukan pada tahap awal, masalah keamanan dapat diperbaiki sebelum aplikasi masuk ke tahap production.

Contoh aktivitas SAST:

- Source code analysis.
- Automated code scanning.
- Manual code review.

- Data flow analysis.

Pendekatan ini sesuai dengan konsep **shift-left security**, yaitu memasukkan security testing sedini mungkin dalam SDLC.

11. DAST

DAST atau **Dynamic Application Security Testing** melakukan pengujian terhadap aplikasi ketika aplikasi sedang berjalan.

DAST melihat aplikasi dari sisi eksternal dan dapat digunakan untuk menemukan vulnerability yang muncul ketika aplikasi berinteraksi dengan request, input, dan environment sebenarnya.

Contohnya adalah melakukan vulnerability scanning dan penetration testing terhadap aplikasi yang sedang berjalan.

12. Software Composition Analysis (SCA)

SCA digunakan untuk memeriksa dependency atau komponen pihak ketiga yang digunakan dalam aplikasi.

Pengujian ini penting karena aplikasi modern biasanya menggunakan banyak library dan package dari pihak lain. Jika salah satu dependency memiliki vulnerability, aplikasi yang menggunakannya juga dapat terkena risiko.

SCA dapat membantu mengidentifikasi dependency yang bermasalah sehingga dapat diperbarui atau diganti.